

Vendor Risk Assessment Report

Vendor: Sample Vendor Ltd.

Date: October 2025

Prepared by: Conley Cyber Advisory

1. Executive Summary

This Vendor Risk Assessment Report provides a comprehensive evaluation of Sample Vendor Ltd.'s information security posture. Sample Vendor Ltd. is a global cloud-based payroll and payments provider handling highly sensitive employee data. The assessment benchmarks Sample Vendor Ltd.'s governance, technical safeguards, and compliance program against ISO 27001, SOC 2, and NIST CSF standards. Based on the analysis, Sample Vendor Ltd. demonstrates strong control maturity, a robust compliance framework, and sound operational security.

Residual risk is assessed as Medium, driven primarily by contractual notification timelines and audit evidence recency.

Findings & Risk Rating Summary:

Sample Vendor Ltd. demonstrates a strong overall security posture with ISO 27001 certification and SOC 2 Type II compliance. One High, two Medium, and one Low risk findings were identified. Overall residual risk rating: ****Medium****. Key focus areas include contractual breach notification SLAs and audit evidence updates.

2. Vendor Profile & Scope

Sample Vendor Ltd. enables multinational companies to manage payroll operations across 130+ countries through a unified SaaS platform. Data processed includes payroll, tax identifiers, and banking details, classified as Highly Sensitive. The assessment covered data handling, access management, encryption, incident response, and regulatory compliance under GDPR and SOC 2. Sample Vendor Ltd.'s ISO/IEC 27001 certification and annual SOC 2 audits confirm adherence to international security standards.

3. Vendor Risk Rating Matrix

Risk Domain	Assessment Focus	Inherent Risk	Control Strength	Residual Risk	Comments
Security	Access control, encryption, network protection	High	Strong	Medium	ISO 27001, SOC 2; robust controls
Privacy & Compliance	GDPR, data handling, breach clauses	High	Moderate	Medium-High	Clarify breach SLA timelines
Operational	Incident response, uptime, resilience	Medium	Strong	Low-Medium	Defined IR plan; strengthen SLA
Financial & Reputational	Stability, reputation, insurance	Medium	Strong	Low	No known breaches; insured

Overall Vendor Risk Rating: High (Inherent) → Medium (Residual)

4. Key Findings & Recommendations

[High] Sensitive Data & Contractual Safeguards – Add Data Security Addendum and 48h breach notification clause.

[Medium] Audit Evidence Currency – Request most recent SOC 2 Type II report or bridging letter before renewal.

[Medium] Incident Response SLA – Negotiate explicit 24-hour notification window for security incidents.

[Low] Sub-processor Transparency – Ensure visibility and approval rights for sub-processor changes.

5. Summary of Recommendations

1. Integrate Data Security Addendum into Sample Vendor Ltd.’s contract.
2. Obtain updated SOC 2 Type II and ISO 27001 evidence annually.
3. Define a 24-hour breach notification SLA.
4. Monitor Sample Vendor Ltd.’s external security posture via rating tools.
5. Conduct annual risk re-assessment of Sample Vendor Ltd. as a high-criticality vendor.

6. Conclusion

Sample Vendor Ltd. maintains a mature, compliant, and reliable information security framework. Its ISO 27001 and SOC 2 certifications confirm operational discipline and control rigor. The residual risk level after recommended improvements is acceptable. Conley Cyber Advisory advises proceeding with onboarding, subject to finalizing contractual safeguards and ongoing monitoring. This assessment reinforces the importance of continuous third-party due diligence to uphold data protection and regulatory compliance.

Vendor Risk Questionnaire

RiskLevel	ScoreMap_Level	ScoreMap_Value
Low	Low	1
Medium	Medium	2
High	High	3

Section	Question (with framework mapping)	Answer (Placeholder)	Vendor Comments	Risk Rating (Low/Medium/High)
General Information	Do you have a formal Information Security Program with documented policies in place?			
General Information	Who is responsible for cybersecurity at your organization (e.g., CISO or Security Officer)?			
General Information	Do you provide regular security awareness training for all employees?			
Data Handling & Storage	How do you classify and handle sensitive data?			
Data Handling & Storage	Is all sensitive customer data encrypted at rest and in transit?			
Data Handling & Storage	Do you have controls to prevent data leakage or unauthorized exfiltration (e.g., DLP)?			
Access Management	Do you enforce strong user authentication and role-based access controls (RBAC)?			
Access Management	How do you manage provisioning/de-provisioning and periodic access reviews?			
Network Security	Do you have a network security policy and protections (firewalls, IDS/IPS)?			
Network Security	Do you monitor security events/logs and use a SIEM?			
Incident Response & BC/DR	Do you have a documented Incident Response Plan and test it?			
Incident Response & BC/DR	Do you have BCP/DR and test backups?			
Compliance & Certifications	Are you compliant/certified (ISO 27001, SOC 2, PCI, GDPR)?			
Vendor Sub-Processors	Do you use sub-processors and manage their security?			

Section	Question	CloudPay Answer	Comments	Risk Rating
General Information	Do you have a formal Information Security Program?	Demo	Demo	Low
General Information	Who is responsible for cybersecurity?	Demo	Demo	Low
Data Handling & Storage	Is all sensitive data encrypted at rest/in transit?	Demo	Demo	Low
Data Handling & Storage	Do you have DLP controls?	Demo	Demo	High
Access Management	RBAC and MFA in place?	Demo	Demo	Low
Network Security	Network policy and protections (FW/IDS/IPS)?	Demo	Demo	Low
Incident Response & BC/DR	Breach notification process?	Demo	Demo	Low
Compliance & Certifications	Standards/regulatory compliance?	Demo	Demo	Medium

Section	Low Count	Medium Count	High Count	Total Questions	Average Risk Score	Risk Level
General Information	2	0	0	2	1	Low
Data Handling & Storage	1	0	1	2	2	Medium
Access Management	1	0	0	1	1	Low
Network Security	1	0	0	1	1	Low
Incident Response & BC/DR	1	2	3	4	3.5	High
Compliance & Certifications	0	1	0	1	2	Medium

Vendor Inventory Tiering Tracker

Vendor Name	Service Type	Data Type Processed	Risk Tier (Low/Med/High)	Review Frequency
Vendor 1	xyz	demo	High	Quarterly
Vendor 2	abc	demo	Medium	Bi-annually
Vendor 3	pqr	demo	Low	Annually
Vendor 4	demo	demo	High	Quarterly
Vendor 5	test	demo	Medium	Bi-annually

Last Review Date	Next Review Date	Assigned Owner	Notes
2025-09-30	2025-12-30	Owner 1	test
2025-06-15	2025-12-15	Owner 2	test
2024-12-10	2025-12-10	Owner 3	test
2025-07-01	2025-10-01	Owner 4	test
2025-04-20	2025-10-20	Owner 5	test

Conley Cyber Advisory Access Control Policy

Purpose & Scope

The purpose of this Access Control Policy is to define how Conley Cyber Advisory protects and controls access to its information systems, networks, and facilities to prevent unauthorized access and safeguard sensitive data. This policy ensures authorized access only, adhering to principles of least privilege, need-to-know, and separation of duties. It aligns with ISO/IEC 27001 and SOC 2 standards by formalizing access control procedures and responsibilities.

This policy applies to all employees, contractors, and third-party users. It covers company-owned and customer-provided information assets, including on-premises and cloud systems (e.g., servers, SaaS, databases), networks, and facilities. The policy includes user account management, authentication mechanisms, and physical access to offices or data centers.

Roles and Responsibilities

Executive Management provides resources for access control implementation, policy approval, and ensures compliance with ISO 27001/SOC 2 requirements.

IT Security / System Administrators manage IAM systems (e.g., Azure AD, Okta), handle account provisioning and monitoring, and enforce compliance.

Department Managers define team access needs, approve access, and perform periodic reviews.

System Owners approve access for critical systems and ensure compliance with least-privilege.

HR notifies IT Security of new hires, changes, or terminations to ensure timely access adjustments.

Employees & Contractors must safeguard credentials, report incidents, and use access only as authorized.

Third-Party/Vendor Users receive limited, monitored access with formal agreements and expiry dates.

Access Provisioning Workflow

Access requests follow a structured, auditable workflow:

1. Access Request Initiation – Managers initiate requests via the ITSM or IAM platform.
2. Approvals – All requests require managerial and system owner approvals; high-privilege access needs IT Security sign-off.
3. Identity Verification – HR onboarding and identity confirmation are mandatory.
4. Account Creation – IT creates accounts with unique IDs in centralized IAM systems (e.g., Azure AD) using least-privilege roles.
5. Credential Setup – Temporary credentials are issued securely; users must reset passwords and enable MFA on first login.
6. Documentation – All requests, approvals, and account configurations are logged for compliance.
7. Revocation – Upon role change or termination, access is promptly revoked, and logs updated.

MFA & Authentication Standards

Multi-Factor Authentication (MFA) is required for all remote, privileged, or sensitive access. Azure AD MFA and Okta Verify are standard tools. Privileged accounts must always use MFA.

Passwords must be at least 12 characters, complex, and rotated periodically. Systems prevent reuse and require password resets on first login.

Accounts are individual; sharing credentials is prohibited. Shared service accounts need IT Security approval and monitoring.

SSO (Single Sign-On) via Okta or Azure AD enforces consistent authentication policies across systems.

Systems enforce lockout after failed logins and session timeouts after 15 minutes of inactivity.

Least-Privilege & Periodic Access Reviews

All access is based on the least-privilege and need-to-know principles. Separation of duties is applied to prevent fraud or misuse.

Access reviews occur at least annually; quarterly for critical systems. Managers and system owners verify that users retain only necessary access.

Event-triggered reviews occur for job changes, system updates, or terminations to eliminate unused privileges.

Access Revocation / Termination Procedures

HR notifies IT Security before or during termination events. IT disables all user accounts (AD, email, VPN, SaaS) on the last day of employment or immediately upon termination.

Physical access (badges, keys) is revoked simultaneously. Shared credentials known by the user are rotated.

Revocation completion is documented and verified by IT and HR to ensure compliance and audit traceability.

Monitoring & Logging

All authentication, privilege, and access events are logged. Logs capture timestamps, users, and actions. Centralized logging via SIEM (e.g., Splunk, Azure Sentinel) enables correlation and alerting.

Alerts trigger for failed logins, privilege changes, or after-hours access. Logs are reviewed regularly and retained for at least 12 months.

Access logs are protected from modification; administrator log access is itself audited.

Exceptions & Violations Handling

Policy exceptions must be formally requested, risk-assessed, and approved by the CISO with expiration dates.

Violations (e.g., password sharing, unauthorized access) result in disciplinary actions, up to termination or legal measures.

Employees are encouraged to report violations without fear of retaliation. This ensures transparency and compliance with ISO 27001 and SOC 2 controls.

Audit Prep Checklist

Control ID (ISO/NIST Mapping)	Requirement Description	Evidence Type / File Path	Control Owner	Status (Open, In Progress, Closed)	Remediation Plan	Due Date	Comments
ISO 27001 A.9.4.2 / NIST PR.AC-7	(Sample) Multi-Factor Authentication enforced for all privileged accounts	Policy Document (MFA_Policy.docx)	(Sample) IT Security Manager	Closed	(Sample) N/A	2025-01-15	(Sample) Fully implemented using Azure AD MFA and Okta Verify
ISO 27001 A.9.2.5 / SOC 2 CC6.3	(Sample) Quarterly user access reviews performed for all systems	Access Review Logs / HR Reports	(Sample) Compliance Officer	Open	(Sample) Implement automated review process and assign quarterly schedule	2025-11-01	(Sample) Pending automation tool deployment
ISO 27001 A.12.4.1 / NIST PR.PT-1	(Sample) System and security logs monitored centrally	SIEM Logs (Splunk / Azure Sentinel)	(Sample) Security Operations Lead	In Progress	(Sample) Finalize alert rules and documentation	2025-09-15	(Sample) Monitoring active; documentation 80% complete